

Yandex Cloud Security Remediation Program

Terraform • IAM/OIDC • Managed Kubernetes Hardening • Policy-as-Code • Supply Chain Security • Audit Evidence

Финальный портфельный отчет / Final Portfolio Report

Публично-безопасное резюме завершено cloud security remediation кейса. Документ подготовлен для демонстрации инженерного результата, доказательной базы, мер безопасности публикации и итоговой готовности проекта к показу техническому интервьюеру, ментору или комиссии.

Public-safe completion report for a cloud security remediation case, focused on reproducibility, evidence, remediation outcomes, and publication readiness.

Repository	w88005215-ctrl / yandex-cloud-security-remediation-program
Final tag	v0.13.15-final-project-completion-report
Final commit	5f14582 — docs: add final project completion report
Latest visible workflow state	IaC Security succeeded for final completion and preceding final audit commits
Cloud state	Retained bootstrap resources and temporary MKS resources removed; no new cloud actions in final reporting phases
Report language	Russian main report + English executive appendix

Дата отчета: 2026-05-14

Статус: завершено, опубликовано, финальные проверки пройдены

1. Паспорт документа

Этот PDF фиксирует итоговый, публично-безопасный отчет по проекту Yandex Cloud Security Remediation Program. Он не заменяет исходные evidence-файлы в репозитории, а собирает их в связную историю: цель проекта, архитектура, реализованные контроли, доказательства, результаты проверок, границы утверждений и выводы для портфолио.

Параметр	Значение
Тип документа	Финальный отчет о завершении проекта / portfolio-grade completion report
Целевая аудитория	Технический интервьюер, security/devsecops mentor, дипломная комиссия, руководитель инженерной команды
Основной язык	Русский; англоязычная секция включена как executive appendix
Evidence-модель	Документы, JSON/CSV/TXT метрики, sanitized command outputs, CI workflow results, final audit reports
Публичная безопасность	В отчете нет raw секретов, cloud token values, Terraform state, kubeconfig, частных runtime-директорий или персонального email

Важная граница отчета. Проверки Gitleaks, Checkov и пользовательские grep/audit rules подтверждают отсутствие блокирующих находок в текущем публичном состоянии репозитория и рабочих файлов. Это не является математической гарантией абсолютного отсутствия чувствительных данных во всех исторических GitHub-событиях, workflow logs или commit metadata; такие внешние артефакты управляются отдельно от содержимого текущего репозитория.

2. Краткое резюме результата

Проект завершен как доказательный cloud security / DevSecOps remediation case. Он демонстрирует не отдельную лабораторную команду, а полный цикл инженерной работы: проектирование контролей, IaC-реализацию, keyless CI/CD через OIDC, проверяемую cloud evidence-базу, Managed Kubernetes hardening, policy-as-code enforcement, supply-chain validation, финальную матрицу контролей, риск-регистр, cross-cloud mapping, очистку облачных ресурсов и публичный аудит репозитория.

Домен	Итоговый результат	Формат доказательства
Infrastructure as Code	Terraform/OpenTofu environments подготовлены, проверены, опубликованы и прошли Checkov с 0 failed checks	Terraform files, Checkov output, IaC exception register
IAM / OIDC	GitHub Actions использует OIDC token exchange вместо долгоживущих cloud keys	workflow evidence, OIDC validation docs, sanitized logs
Managed Kubernetes	Проведены short-lived cloud runs, baseline/remediation сценарии и admission-control проверка	MKS evidence, Kyverno denial/allow outputs, cleanup evidence
Policy-as-Code	Небезопасный workload блокируется admission policy; hardened workload проходит	Kyverno policy package, validation logs, after evidence
Supply Chain	SBOM и vulnerability reports собраны для insecure/hardened образов; зафиксировано измеримое улучшение	Syft SBOM, Trivy/Grype outputs, metrics docs
Governance	Итоговая control matrix, risk register, publication readiness и cross-cloud mapping подготовлены	Markdown reports, JSON/CSV/TXT metrics
Publication Safety	Финальный аудит, санитизация, Gitleaks и Checkov завершены успешно	Final repository audit EN/RU, sanitization reports, CI results

2.1. Главная ценность кейса

Кейс показывает способность построить безопасный cloud-native контур не только на уровне “запустить Kubernetes”, а на уровне инженерного процесса: найти слабое состояние, формализовать контроль, реализовать исправление кодом, проверить автоматическими инструментами, подтвердить результат evidence-файлами и безопасно опубликовать артефакты.

- Показан полный remediation lifecycle: insecure baseline → assessment → remediation as code → policy enforcement → CI/CD validation → supply-chain checks → before/after metrics → audit evidence.
- Подтвержден keyless подход для CI/CD: облачный доступ строится через OIDC federation, а не через статические ключи в репозитории.
- Реализована доказательная модель: результаты не описаны “на словах”, а подтверждены командами, метриками, отчетами и финальными audit outputs.
- Завершена уборка облака: retained bootstrap registry/bucket/audit resources и временные Kubernetes/compute/NLB ресурсы удалены.
- Подготовлен публичный репозиторий с безопасной санитизацией и финальным статусом CI security gate.

3. Архитектура проекта

Архитектура проекта построена вокруг provider-aware реализации в Yandex Cloud и provider-agnostic governance model. Практическая часть выполнена в Yandex Cloud, а control mapping показывает переносимость подхода на AWS, GCP и Azure без утверждения, что эти облака реально разворачивались в рамках данного проекта.

Слой	Назначение	Реализованные элементы
Repository / Evidence Layer	Хранение кода, документации, evidence и отчетов	README, docs/, evidence/command-outputs/, evidence/metrics/, final reports EN/RU
IaC Layer	Управляемое описание инфраструктуры	Terraform environments для bootstrap/OIDC/audit, cloud smoke, managed Kubernetes cloud-run
Identity Layer	Безопасная аутентификация CI/CD без long-lived keys	GitHub Actions OIDC federation, token exchange, service accounts, scoped roles
Audit / Registry Layer	Сбор audit evidence и supply-chain артефактов	Audit Trails, Object Storage bucket, Container Registry, SBOM/vulnerability outputs
Kubernetes Layer	Baseline/remediation и admission policy enforcement	Managed Kubernetes, insecure/hardened manifests, Kyverno policies
Validation Layer	Автоматические security gates	Gitleaks, Checkov, Trivy, Grype, Syft, kubecti/Kyverno checks
Governance Layer	Объяснимость и управленческая доказательность	Control matrix, risk register, cross-cloud mapping, cleanup plan, publication readiness

3.1. Сквозной workflow

Insecure baseline → Control assessment → Remediation as Code → Policy enforcement → CI/CD validation → SBOM/vulnerability validation → Before/after metrics → Audit evidence → Cleanup → Public-safe publication

Именно этот сквозной workflow делает проект сильнее обычной лаборатории: каждая техническая часть соединена с доказательством результата и с ограничением публичных утверждений.

4. Реализованный объем работ

Фаза	Что закрыто	Ключевой результат
Foundation / repository	Структура проекта, evidence-подход, документация, безопасные правила публикации	Репозиторий стал воспроизводимой инженерной базой, а не набором разрозненных команд
Yandex Cloud readiness	ys CLI, Terraform, kubectl, gitleaks, базовые проверки облачной готовности	Подтверждено, что controlled cloud runs могут выполняться с фиксацией evidence
Managed Kubernetes smoke-run	Короткий lifecycle прогон кластера: create → access → node ready → destroy	Доказано, что инфраструктура создается и удаляется управляемо
Bootstrap / OIDC / Audit	Service accounts, OIDC federation, registry, audit bucket, Audit Trails	Подготовлена база для keyless CI/CD и audit evidence
GitHub Actions OIDC	Token exchange между GitHub OIDC и Yandex Cloud IAM	Long-lived cloud keys не требуются для workflow
Registry / supply chain	Сборка и push demo images через OIDC, SBOM и vulnerability scanning	Появилась измеримая supply-chain evidence база
Kubernetes hardening	Insecure baseline, hardened manifests, Kyverno admission policy	Небезопасное состояние блокируется политикой, hardened workload допускается
Metrics / governance	Final metrics, control matrix, risk register, cross-cloud mapping	Результат переведен в язык контролей, рисков и аудита
Cleanup / publication	Удаление retained bootstrap resources, final audit, sanitization, final reports	Проект завершен и безопасен для публичного показа

5. Evidence-модель и проверяемость

Проект построен так, чтобы итоговые утверждения можно было проверить по артефактам. Вместо разового “успешно запустилось” используется evidence chain: команды, sanitized outputs, JSON/CSV/TXT метрики, документы, финальные git control outputs, CI results и отчеты о санитизации.

5.1. Основные evidence-категории

Категория	Примеры артефактов	Что доказывает
Command outputs	evidence/command-outputs/YCSEC_*	Фактическое выполнение команд, validation steps, cleanup checks, CI/security tool outputs
Metrics	final_remediation_metrics.json, final_control_matrix.json, final_risk_register.json, final_repository_audit.json	Итоговые показатели, статус контролей, риски и результаты аудита
Security reports	SBOM, Trivy, Gype, Checkov, Gitleaks outputs	Supply-chain и IaC/security validation
Kubernetes evidence	Kyverno insecure denied / hardened allowed outputs	Admission policy работает не декларативно, а проверено practically
Governance docs	final-control-matrix, final-risk-register, final-publication-readiness	Проект понятен как управляемая security program, а не только техническая лаборатория
Bilingual reports	final technical reports, repository audit, sanitization, completion report	Материалы готовы для RU/EN демонстрации

5.2. Финальные статусы проверок

Проверка	Финальный статус	Интерпретация
GitHub Actions / IaC Security	PASS на последних финальных push-событиях	Исторические failed runs остались как следы исправлений; текущий финальный путь зеленый
Checkov	Passed checks: 27; Failed checks: 0; Skipped checks: 11	IaC security gate стабилизирован; исключения оформлены как контролируемые и документированные
Gitleaks	No leaks found	Финальный secret scan не выявил утечек в проверяемом состоянии репозитория
Repository artifact safety	No Terraform state / kubeconfig / PEM / env / key JSON artifacts	Приватные runtime artifacts не попали в публичный репозиторий
Cloud cleanup	Bootstrap registry/bucket/audit resources removed; temporary MKS/compute/NLB absent	Ресурсы, создававшие расходы или живое облачное состояние, закрыты
Public wording safety	No internal or unprofessional wording found	Публичная документация приведена в профессиональный вид

6. Security outcomes

Итоговые security outcomes сформулированы как измеримые или проверяемые результаты. Каждый outcome связан с артефактами в репозитории и не опирается на неподтвержденные заявления.

Outcome	Before / risk	After / control
Keyless CI/CD	Риск использования долгоживущих cloud keys в CI/CD	OIDC token exchange и scoped service account access без публикации ключей
IaC posture	Terraform может содержать небезопасные patterns и scanner failures	Checkov стабилизирован: 0 failed checks; исключения документированы и привязаны к ресурсу
Kubernetes exposure	Insecure workload и слабые pod settings могли пройти без enforcement	Kyverno блокирует insecure workload и пропускает hardened workload
Supply-chain visibility	Образы без SBOM и vulnerability evidence	Syft/Trivy/Grype evidence, insecure vs hardened comparison, vulnerability metrics
Auditability	Невозможно доказать, что cloud actions выполнялись контролируемо	Command outputs, audit evidence, cleanup verification, final reports
Publication safety	Риск публикации runtime state, kubeconfig, email, token-like artifacts	Санитизация, Gitleaks, custom repository audit, bilingual audit reports

6.1. Что особенно важно для интервью

Проект демонстрирует инженерную зрелость на стыке Cloud Security, DevSecOps, Kubernetes Security и Security Governance. Он показывает не “знакомство с инструментами”, а способность выстроить процесс так, чтобы результат можно было повторить, проверить и защитить перед техническим интервьюером.

- Понимание cloud IAM и федерации идентичности: поли, service accounts, OIDC federation, ограничение long-lived credentials.
- Умение работать с Terraform как с контролируемым security artifact, включая scanner exceptions с обоснованием.
- Практическая Kubernetes security: baseline, hardening, admission policy, evidence-based allow/deny validation.
- Supply-chain security: registry workflow, SBOM, vulnerability scanning, comparison of insecure/hardened images.

- Аудиторская дисциплина: evidence index, risk register, control matrix, final audit, cleanup, publication boundary.

7. Публичная безопасность и санитизация

Финальная публикационная часть была выделена в отдельный этап, потому что портфельный security-проект сам должен проходить security hygiene. Были проверены публичные документы, evidence, metrics, scanner outputs и рабочее состояние репозитория.

Направление проверки	Что сделано	Итог
Raw secrets	Gitleaks по репозиторию и финальная проверка после санитизации	No leaks found
Cloud runtime artifacts	Поиск Terraform state, kubeconfig, PEM, env/key JSON и подобных файлов	Блокирующие артефакты отсутствуют
Scanner metadata	GPG_KEY-like false positives в Trivy evidence обработаны безопасно	Gitleaks workflow перестал падать
Public email strings	Email-like строки в public command outputs заменены на безопасные placeholders	Личные email-строки удалены из проверяемых файлов репозитория
Cloud identifiers	Resource IDs, registry/image IDs, bucket/folder/service-account-like markers приведены к placeholders в публичных evidence	Снижена связность публичных артефактов с конкретными облачными объектами
Unprofessional/internal wording	Проверка README/docs/metrics/evidence на недопустимые слова и внутренние workflow-следы	Блокирующих находок нет

Ограничение: GitHub как платформа может сохранять commit metadata, workflow logs и historical run records. В текущем отчете подтверждается состояние опубликованных файлов репозитория и финальных проверок, а не полная перезапись всей истории GitHub-платформы.

8. Облачная очистка и cost-control

Проект изначально строился как cost-conscious cloud run: локальная подготовка, короткие контролируемые облачные прогоны и обязательная cleanup verification. Финальная очистка закрыла retained bootstrap resources, которые ранее сохранялись для OIDC, registry, audit и supply-chain evidence.

Ресурсный класс	Финальный статус	Значение для проекта
Container Registry	Удален после очистки images	Закрит источник расходов и retained state
Object Storage audit bucket	Удален после очистки содержимого	Audit evidence перенесена в sanitized public artifacts; live bucket не оставлен
Audit Trails trail	Удален	Bootstrap audit stage закрыт
Bootstrap service accounts / federation	Удалены	Нет retained cloud identities после завершения проекта
Temporary Managed Kubernetes	Отсутствует	Нет платного MKS кластера после прогонов
Compute / NLB	Отсутствуют	Нет временных node/compute/LB ресурсов

8.1. Почему это важно

Для cloud security проекта недостаточно создать ресурсы. Необходимо доказать, что они удалены, потому что незакрытая инфраструктура — это одновременно финансовый риск, operational risk и security risk. Отдельная cleanup evidence делает проект зрелым и безопасным для публичной демонстрации.

9. Governance: control matrix, risk register, cross-cloud mapping

Проект завершен не только техническими проверками, но и governance-слоем: матрицей контролей, риск-регистром, remediation metrics и mapping к AWS/GCP/Azure control concepts. Это переводит технический проект в формат, понятный руководителю безопасности, аудитору или техническому лиду.

Артефакт	Роль	Практическая ценность
Final Control Matrix	Связывает controls, evidence, validation status и implementation artifacts	Позволяет быстро доказать, какие security controls реально закрыты
Final Risk Register	Фиксирует риски, mitigations, residual risk и evidence links	Показывает зрелое risk-based thinking
Final Remediation Metrics	Сводит before/after outcomes и security improvements	Делает результат измеримым
Cross-cloud Control Mapping	Соотносит идеи проекта с AWS/GCP/Azure control domains	Показывает переносимость подхода без ложных claimов о реальном multi-cloud deployment
Publication Readiness	Фиксирует границы публикации и допустимые утверждения	Снижает риск overclaiming и утечек

10. Границы утверждений

Качественный портфельный отчет должен явно разделять доказанные факты и недоказанные претензии. Это повышает доверие к проекту и снижает риск overclaiming.

Что можно утверждать	Что нельзя утверждать без отдельного evidence
Yandex Cloud infrastructure и Managed Kubernetes прогонялись контролируемыми short-lived runs	Нельзя утверждать, что AWS/GCP/Azure ресурсы были реально развернуты
GitHub Actions OIDC validation выполнена и задокументирована	Нельзя утверждать, что все возможные production IAM сценарии покрыты
Kyverno admission policy validated: insecure denied, hardened allowed	Нельзя утверждать полноценный production-grade Kubernetes runtime hardening всего кластера
SBOM/vulnerability evidence собрана для demo images	Нельзя утверждать полный enterprise SDLC или runtime vulnerability management
Gitleaks/Checkov/final audit passed в текущем состоянии репозитория	Нельзя гарантировать отсутствие всех исторических платформенных metadata/logs на стороне GitHub

11. Позиционирование проекта в портфолио

Проект можно использовать как сильный завершенный кейс для направлений Cloud Security Engineer, DevSecOps Engineer, Kubernetes Security, Security Automation, Infrastructure Security и технического управления security remediation programs.

Компетенция	Как подтверждается проектом
Cloud Security Engineering	IAM/OIDC, audit evidence, cloud cleanup, controlled Yandex Cloud runs
DevSecOps / CI Security	GitHub Actions, keyless registry push, Gitleaks, Checkov, security gates
Kubernetes Security	Managed Kubernetes, insecure/hardened manifests, Kyverno admission enforcement
Supply Chain Security	Container Registry, SBOM, Trivy, Gype, vulnerable/hardened image comparison
IaC Security	Terraform environments, Checkov stabilization, documented scanner exceptions
Audit / Governance	Control matrix, risk register, evidence index, final reports, publication readiness

Компетенция	Как подтверждается проектом
Evidence discipline	Sanitized command outputs, JSON/CSV/TXT metrics, final git control evidence

11.1. Короткая формулировка для резюме

Реализовал Yandex Cloud Security Remediation Program: Terraform/IaC, IAM least privilege, GitHub Actions OIDC без long-lived ключей, Managed Kubernetes hardening, Kyverno policy-as-code, SBOM/vulnerability validation, Gitleaks/Checkov gates, audit-ready evidence, risk register, control matrix, remediation metrics и финальную публичную санитизацию репозитория.

11.2. Сильная формулировка для технического интервью

Проект показывает end-to-end cloud security remediation workflow: от небезопасного baseline и cloud evidence до remediation as code, admission policy enforcement, supply-chain security checks, risk-based reporting, cleanup verification и publication-safe final audit. Все ключевые claims подтверждены evidence-файлами и финальными CI/security checks.

12. Карта ключевых артефактов

Путь / файл	Назначение
README.md	Главная публичная витрина проекта и навигация по финальным отчетам
docs/final-technical-report-ru.md / en.md	Итоговый технический отчет на двух языках
docs/final-project-completion-report-ru.md / en.md	Финальный отчет о завершении проекта
docs/final-repository-audit-ru.md / en.md	Аудит репозитория и результаты проверки публикационной безопасности
docs/publication-sanitization-report-ru.md / en.md	Отчет о санитизации публичных артефактов
docs/final-control-matrix.md	Матрица контролей и evidence linkage
docs/final-risk-register.md	Финальный риск-регистр
docs/final-remediation-metrics.md	Итоговые remediation metrics
docs/iac-security-exceptions.md	Обоснование Checkov exceptions
evidence/metrics/*.json / *.csv / *.txt	Машиночитаемые и человекочитаемые итоговые метрики
evidence/command-outputs/YCSEC_*	Sanitized command evidence по фазам
evidence/sbom/*	CycloneDX SBOM для supply-chain validation
evidence/vulnerability/*	Trivy/Grype vulnerability evidence

13. Итоговый вывод

Проект можно считать завершенным в портфельном смысле: он имеет финальный tag, опубликованную доказательную базу, успешные финальные CI/security checks, cleanup cloud resources, финальные RU/EN отчеты, аудит репозитория, санитизацию публикационных артефактов и clear boundaries для публичных claimов.

Критерий завершения	Статус
Техническая реализация	Закрыта
Cloud evidence	Закрыта; retained ресурсы удалены
Kubernetes / Kyverno evidence	Закрыта
Supply-chain evidence	Закрыта

Критерий завершения	Статус
Final metrics / control matrix / risk register	Закрыты
Public audit / sanitization	Закрыты
CI security gates	Финальные runs успешны
Portfolio readiness	Готово к демонстрации

Финальная оценка: это не “черновой лабораторный проект”, а завершённый evidence-based cloud security remediation case, который можно показывать как самостоятельный инженерный результат.

14. English Executive Appendix

This appendix summarizes the same project in English for international-style portfolio review. The detailed evidence remains in the repository: command outputs, metrics, final reports, risk register, control matrix, repository audit, sanitization report, SBOM and vulnerability artifacts.

14.1. Executive summary

The Yandex Cloud Security Remediation Program is a completed cloud security and DevSecOps remediation case. It demonstrates Infrastructure as Code, IAM least privilege, keyless GitHub Actions access through OIDC, Managed Kubernetes baseline/remediation validation, policy-as-code enforcement with Kyverno, container supply-chain validation, audit-ready evidence, final remediation metrics, a control matrix, a risk register, cross-cloud control mapping, cloud cleanup, and publication-safe repository audit.

Domain	Completed outcome	Evidence type
IaC Security	Terraform environments validated; Checkov stabilized with 0 failed checks and documented exceptions	Terraform files, Checkov output, exception register
Identity / CI/CD	GitHub Actions OIDC token exchange validated without long-lived cloud keys	Workflow evidence, OIDC validation docs
Kubernetes Security	Short-lived Managed Kubernetes evidence runs and Kyverno admission validation completed	MKS/Kyverno evidence outputs
Supply Chain	SBOM and vulnerability evidence generated for insecure and hardened demo images	Syft, Trivy, Gripe artifacts
Governance	Final metrics, control matrix, risk register, and cross-cloud mapping produced	Markdown reports and machine-readable metrics
Publication Safety	Repository audit, sanitization, Gitleaks, Checkov, and cleanup verification completed	Final audit and sanitization reports

14.2. What the project proves

- The project demonstrates an evidence-based remediation lifecycle rather than a single isolated tool run.
- Cloud access for CI/CD is modeled through OIDC federation and scoped cloud identities instead of repository-stored static credentials.
- Kubernetes workload hardening is validated through an admission-control path: insecure workload denied, hardened workload allowed.
- Supply-chain visibility is supported with SBOM and vulnerability reports for baseline and hardened images.
- Security posture is communicated through a control matrix, risk register, remediation metrics, final reports, and publication boundaries.

14.3. Publication boundary

The project uses Yandex Cloud as the real implementation provider. AWS, GCP, and Azure references are control-concept mappings only. The repository does not claim that AWS, GCP, or Azure resources were deployed unless separate evidence exists. Final Gitleaks and Checkov checks passed for the current repository state; this does not assert control over external GitHub platform metadata or historical workflow logs outside the repository content.

14.4. Final state

Item	Final state
Final project tag	v0.13.15-final-project-completion-report
Final project commit	5f14582 — docs: add final project completion report
Latest IaC Security workflow state	Successful for the final completion report and preceding final audit commits
Gitleaks	No leaks found
Checkov	27 passed, 0 failed, 11 skipped with documented exceptions
Retained bootstrap cloud resources	Removed
Temporary MKS/Compute/NLB resources	Absent
Portfolio status	Ready for demonstration

15. Appendix: Report integrity note

This PDF is a public-safe narrative report generated from the final project state and terminal evidence supplied during the closeout process. It intentionally avoids raw identifiers, live secrets, private local paths, kubeconfigs, Terraform state, personal email, or internal conversation content. For formal verification, reviewers should inspect the repository files and final CI/security outputs directly.